Estratégia Concursos

Aula 36

DataPrev (Analista de TI - Desenvolvimento de Software) Passo Estratégico de Conhecimentos Específicos - 2024 (Pós-Edital)

Autor:

09 de Setembro de 2024

11225354498 - Maria Vitória Gonçalves Vieira

ISO 27002:2022

Sumário

Conteúdo 1

Glossário de termos 3

Roteiro de revisão 11

Conceitos Básicos 11

Requisitos do SGSI 15

Controles Organizacionais (Seção 5) 16

Controles de Pessoas (Seção 6) 27

Controles Físicos (Seção 7) 30

Controles Tecnológicos (Seção 8) 34

Aposta estratégica 44

Questões Estratégicas 45

Questionário de revisão e aperfeiçoamento 54

Perguntas 54

Perguntas e Respostas 55

Lista de Questões Estratégicas 58

Gabaritos 61

CONTEÚDO

ISO 27002. Conceitos Básicos. Seções de Controle. Controles Organizacionais. Controles de pessoas. Controles físicos. Controles tecnológicos.

11225354498 - Maria Vitória Gonçalves Vieira

ANÁLISE ESTATÍSTICA

Inicialmente, convém destacar o percentual de incidência do assunto, dentro da disciplina **Segurança da Informação** em concursos/cargos similares. Quanto maior o percentual de cobrança de um dado assunto, maior sua importância.

Obs.: *um mesmo assunto pode ser classificado em mais de um tópico devido à multidisciplinaridade de conteúdo*.

Assunto	Relevância na disciplina em concursos similares
Criptografia	**11.4 %**
Análise de Vulnerabilidade e Gestão de Riscos	**11.4 %**
Plano de Continuidade de Negócios	**8.6 %**
Norma 27005	**8.6 %**
Backup em Segurança da Informação	**5.7 %**
Conceitos Básicos em Segurança da Informação	**5.7 %**
Políticas de Segurança de Informação	**5.7 %**
Norma ISO 27001/27002	**5.7 %**
Certificação Digital em Segurança da Informação	**5.7 %**
Ataques e ameaças	**5.7 %**
Planos de contingência	**2.9 %**
Sistemas de Prevenção-Detecção de Intrusão	**2.9 %**
1. IDS (Intrusion Detection System)	**2.9 %**
2. IPS (Intrusion Prevention System)	**2.9 %**
Segurança de sistemas de informação	**2.9 %**
Infraestrutura de Chaves Publicas (PKI)	**2.9 %**
Controles de segurança	**2.9 %**
Assinatura Digital	**2.9 %**

11225354498 - Maria Vitória Gonçalves Vieira

Malware	**2.9 %**

GLOSSÁRIO DE TERMOS

Faremos uma lista de termos que são relevantes ao entendimento do assunto desta aula. Caso tenha alguma dúvida durante a leitura, esta seção pode lhe ajudar a esclarecer.

Vamos listar os termos do glossário de acordo como eles aparecem na norma 27000 (a base da "família de normas")

3.1 controle de acesso

meios para garantir que o acesso a ativos seja autorizado e restrito com base nos requisitos comerciais e de segurança

3.2 ataque

tentativa de destruir, expor, alterar, desabilitar, roubar ou obter acesso não autorizado ou uso não autorizado de um ativo

3.3 auditoria

processo sistemático, independente e documentado para obter evidências de auditoria e avaliá-las de forma objetiva para determinar a extensão em que os critérios de auditoria são cumpridos definidos na ISO 19011.

3.4 escopo da auditoria

extensão e limites de uma auditoria

3.5 autenticação

11225354498 - Maria Vitória Gonçalves Vieira

provisão de garantia de que uma característica reivindicada de uma entidade está correta

3.6 autenticidade

propriedade de que uma entidade é o que ela afirma ser

3.7 disponibilidade

propriedade de ser acessível e utilizável sob demanda por uma entidade autorizada

3.8 medida de base

medida definida em termos de um atributo e o método para quantificá-lo

3.9 competência

habilidade de aplicar conhecimentos e habilidades para alcançar resultados pretendidos

3.10 confidencialidade

propriedade de que a informação não é disponibilizada ou divulgada a indivíduos, entidades ou processos não autorizados

3.11 conformidade

cumprimento de um requisito

3.12 consequência

resultado de um evento afetando objetivos

11225354498 - Maria Vitória Gonçalves Vieira

3.13 melhoria contínua

atividade recorrente para aprimorar o desempenho

3.14 controle

medida que modifica o risco

3.15 objetivo de controle

afirmação que descreve o que deve ser alcançado como resultado da implementação dos controles

3.16 correção

ação para eliminar uma não conformidade detectada

3.17 ação corretiva

ação para eliminar a causa de uma não conformidade e prevenir a recorrência

3.18 medida derivada

medida que é definida como função de dois ou mais valores de medidas de base

3.19 informação documentada

informação que deve ser controlada e mantida por uma organização e o meio no qual ela está contida

11225354498 - Maria Vitória Gonçalves Vieira

3.20 eficácia

extensão em que as atividades planejadas são realizadas e os resultados planejados são alcançados

3.21 evento

ocorrência ou mudança de um conjunto específico de circunstâncias

3.22 contexto externo

ambiente externo no qual a organização busca alcançar seus objetivos

3.23 governança da segurança da informação

sistema pelo qual as atividades de segurança da informação de uma organização são dirigidas e controladas

3.24 órgão de governança

pessoa ou grupo de pessoas responsáveis pelo desempenho e conformidade da organização

3.25 indicador

medida que fornece uma estimativa ou avaliação

3.26 necessidade de informação

insight necessário para gerenciar objetivos, metas, riscos e problemas

11225354498 - Maria Vitória Gonçalves Vieira

3.27 instalações de processamento de informações

qualquer sistema de processamento de informações, serviço ou infraestrutura, ou o local físico onde está localizado

3.28 segurança da informação

preservação da confidencialidade, integridade e disponibilidade da informação

3.29 continuidade da segurança da informação

processos e procedimentos para garantir operações contínuas de segurança da informação

3.30 evento de segurança da informação

ocorrência identificada de um estado de sistema, serviço ou rede que indica uma possível violação da política de segurança da informação ou falha nos controles, ou uma situação previamente desconhecida que pode ser relevante para a segurança

3.31 incidente de segurança da informação

um único ou uma série de eventos de segurança da informação indesejados ou inesperados que têm uma probabilidade significativa de comprometer as operações comerciais e ameaçar a segurança da informação

3.32 gerenciamento de incidentes de segurança da informação

conjunto de processos para detectar, relatar, avaliar, responder, lidar com e aprender com incidentes de segurança da informação

11225354498 - Maria Vitória Gonçalves Vieira

3.33 profissional do sistema de gestão de segurança da informação

pessoa que estabelece, implementa, mantém e melhora continuamente um ou mais processos do sistema de gestão de segurança da informação

3.34 comunidade de compartilhamento de informações

grupo de organizações que concordam em compartilhar informações

3.35 sistema de informação

conjunto de aplicativos, serviços, ativos de tecnologia da informação ou outros componentes de manipulação de informações

3.36 integridade

propriedade de precisão e completude

3.37 parte interessada

pessoa ou organização que pode afetar, ser afetada ou perceber-se afetada por uma decisão ou atividade

3.38 contexto interno

ambiente interno no qual a organização busca alcançar seus objetivos

3.39 nível de risco

magnitude de um risco expressa em termos da combinação de consequências e sua probabilidade

11225354498 - Maria Vitória Gonçalves Vieira

3.40 probabilidade

chance de algo acontecer

3.41 sistema de gestão

conjunto de elementos inter-relacionados ou interagindo de uma organização para estabelecer políticas e objetivos e processos para alcançar esses objetivos

3.42 medida

variável à qual um valor é atribuído como resultado de medição

3.43 medição

processo para determinar um valor

3.44 função de medição

algoritmo ou cálculo realizado para combinar duas ou mais medidas de base

3.45 método de medição

sequência lógica de operações, descrita de forma genérica, usada para quantificar um atributo em relação a uma escala especificada

3.46 monitoramento

determinação do estado de um sistema, um processo ou uma atividade

11225354498 - Maria Vitória Gonçalves Vieira

3.47 não conformidade

não cumprimento de um requisito

3.48 não repúdio

habilidade de provar a ocorrência de um evento ou ação reivindicada e suas entidades de origem

3.49 objetivo

resultado a ser alcançado

3.50 organização

pessoa ou grupo de pessoas que possui suas próprias funções com responsabilidades, autoridades e relacionamentos para alcançar seus objetivos

3.51 terceirizar

fazer um acordo em que uma organização externa executa parte da função ou processo de uma organização

3.52 desempenho

resultado mensurável

3.53 política

intenções e direção de uma organização, expressas formalmente por sua alta administração

11225354498 - Maria Vitória Gonçalves Vieira

3.54 processo

conjunto de atividades inter-relacionadas ou interativas que transformam entradas em saídas

3.55 confiabilidade

propriedade de comportamento e resultados consistentes e intencionais

3.56 requisito

necessidade ou expectativa que é declarada, geralmente implícita ou obrigatória

3.57 risco residual

risco restante após o tratamento de risco

3.58 revisão

atividade realizada para determinar a adequação, suficiência e eficácia do assunto em questão para alcançar objetivos estabelecidos

3.59 objeto de revisão

item específico sendo revisado

3.60 objetivo de revisão

declaração descrevendo o que deve ser alcançado como resultado de uma revisão

11225354498 - Maria Vitória Gonçalves Vieira

3.61 risco

efeito da incerteza nos objetivos

3.62 aceitação

decisão de assumir um risco específico

3.63 tratamento de risco

processo para modificar o risco

3.64 requisito de segurança da informação

necessidade ou expectativa que é declarada, geralmente implícita ou obrigatória, relacionada à segurança da informação

3.65 risco inaceitável

risco que excede o nível de risco tolerado pela organização

3.66 risco tolerável

risco dentro do nível de risco tolerado pela organização

3.67 risco aceitável

risco que é aceito explicitamente

11225354498 - Maria Vitória Gonçalves Vieira

3.68 conformidade legal

conformidade com leis, regulamentos, obrigações contratuais, requisitos acordados e regras ou normas relevantes

3.69 ameaça

potencial causa de um incidente de segurança da informação que pode resultar em dano à organização ou suas partes interessadas

3.70 valor

grau em que um conjunto de características de uma entidade satisfaz os requisitos estabelecidos pelo cliente, usuário ou outra entidade

3.71 vulnerabilidade

fraqueza de um ativo ou grupo de ativos que pode ser explorada por uma ou mais ameaças

3.72 tratamento de risco

processo para modificar o risco

3.73 tratamento de risco residual

processo para modificar o risco residual

3.74 avaliação de risco

processo de comparação do nível de risco com critérios de risco para determinar se o nível de risco é tolerável ou se o risco precisa ser tratado

11225354498 - Maria Vitória Gonçalves Vieira

3.75 critério de risco

conjunto de critérios usados para avaliar o risco com base nos resultados da análise de risco e determinar a aceitabilidade do risco

3.76 análise de risco

processo para compreender a natureza do risco e determinar o nível de risco

3.77 plano de tratamento de risco

plano que identifica os controles selecionados e ações corretivas a serem implementados para tratar o risco de acordo com critérios de risco e recursos disponíveis

3.78 ponto de partida

condição que existe antes de um projeto, processo ou atividade iniciar

3.79 ambiente

entorno no qual uma organização opera, incluindo aspectos culturais, sociais, políticos, regulatórios, financeiros, tecnológicos, econômicos, naturais e competitivos

3.80 acordo

consenso entre duas ou mais partes que pode ser verbal, escrito ou implícito

3.81 procedimento

forma especificada de realizar uma atividade ou um processo

11225354498 - Maria Vitória Gonçalves Vieira

3.82 monitoramento de segurança da informação

processo sistemático e repetitivo de avaliar a segurança da informação de uma organização para determinar se os controles são eficazes e estão sendo aplicados corretamente

3.83 exposição ao risco

situação em que um indivíduo, organização, ativo ou grupo de ativos está exposto a uma ameaça específica

3.84 segurança

estado de ser livre de perigo, dano ou risco

3.85 processo de gestão de segurança da informação

conjunto de processos coordenados que estabelecem, implementam, operam, monitoram, analisam criticamente, mantêm e melhoram o sistema de gestão de segurança da informação

3.86 programa de segurança da informação

conjunto de atividades planejadas que visam alcançar os objetivos de segurança da informação

3.87 avaliação

processo sistemático, documentado e independente para obter evidências de auditoria e avaliá-las de forma objetiva para determinar a extensão em que os critérios de avaliação são atendidos

11225354498 - Maria Vitória Gonçalves Vieira

3.88 objetivo de avaliação

afirmação que descreve o que deve ser alcançado como resultado da avaliação

3.89 autorização

aprovação formal para prosseguir com uma atividade ou processo

3.90 risco aceitável

risco que é aceito explicitamente

ROTEIRO DE REVISÃO

A ideia desta seção é apresentar um roteiro para que você realize uma revisão completa do assunto e, ao mesmo tempo, destacar aspectos do conteúdo que merecem atenção.

Conceitos Básicos

ISO 27002 é a norma utilizada para as organizações usarem como uma referência na seleção de controles dentro do processo de implementação de um sistema de gestão da segurança da informação (SGSI), baseado na ABNT NBR ISO/IEC 27001 ou como um documento de orientação para as organizações implementarem controles de segurança da informação comumente aceitos.

Esta Norma é também usada no desenvolvimento de organizações e indústrias especificas de gerenciamento de segurança da informação, levando em consideração os seus ambientes de risco de segurança da informação específicos. Organizações de todos os tipos e tamanhos (Ex: o setor privado e público, organizações comerciais e sem fins lucrativos), coletam, processam, armazenam e transmitem informações em diferentes formatos, incluindo o eletrônico, físico e verbal.

11225354498 - Maria Vitória Gonçalves Vieira

O valor da informação vai além das palavras escritas, números e imagens: conhecimento, conceitos, ideias e marcas são exemplos de formas intangíveis da informação. Em um mundo interconectado, a informação e os processos relacionados, sistemas, redes e pessoas envolvidas nas suas operações, são informações que, como outros ativos importantes, têm valor para o negócio da organização e, consequentemente, requer proteção contra vários riscos.

Ativos são objeto de ameaças, tanto acidentais como deliberadas, enquanto os processos, sistemas, redes e pessoas têm vulnerabilidades inerentes ou próprias. Mudanças nos processos e sistemas do negócio ou outras mudanças externas (tais como novas legislações, regulamentações, entre outros) podem criar novos riscos de segurança da informação.

Desta forma, em função das várias maneiras nas quais as ameaças podem se aproveitar das vulnerabilidades para causar dano à organização, os riscos de segurança da informação estão sempre presentes. Uma segurança da informação eficaz reduz estes riscos, protegendo a organização das ameaças e vulnerabilidades e, assim, reduzindo o impacto aos seus ativos. E isso é cada vez mais importante no mundo digitalizado atual.

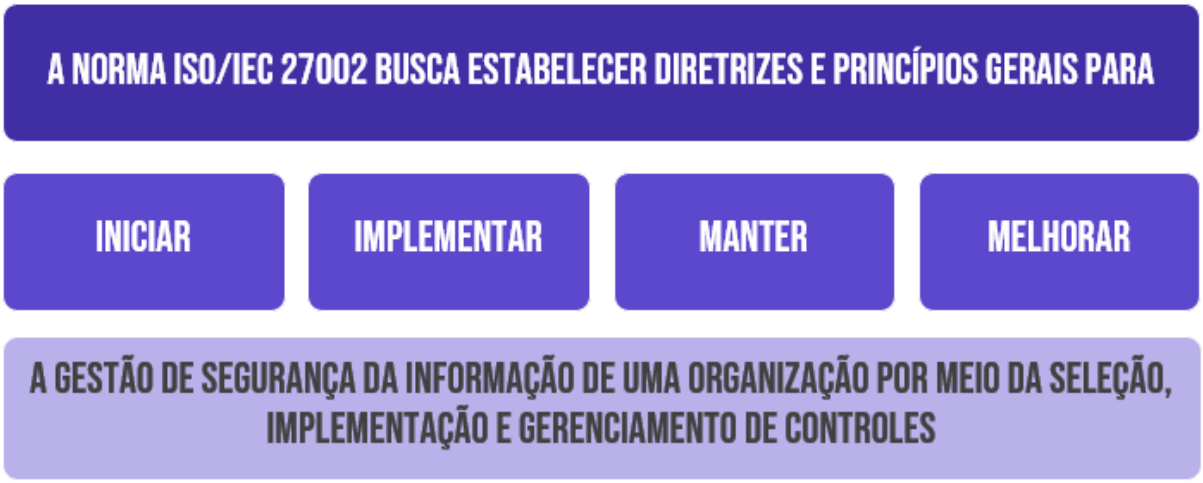
A segurança da informação é alcançada pela implementação de um conjunto adequado de controles, incluindo políticas, processos, procedimentos, estrutura organizacional e funções de software e hardware. Estes controles precisam ser estabelecidos, implementados, monitorados, analisados criticamente e melhorados, quando necessário, para assegurar que os objetivos do negócio e a segurança da informação da organização são atendidos.

Um Sistema de Gestão da Segurança da Informação (SGSI), a exemplo do especificado na ISO/IEC 27001, considera uma visão holística e coordenada dos riscos de segurança da informação da organização, para implementar um conjunto de controles de segurança da informação detalhado, com base na estrutura global de um sistema de gestão coerente. Muitos sistemas de informação não têm sido projetados para serem seguros, na ótica da ABNT NBR ISO/IEC 27001 e desta Norma.

A segurança que pode ser alcançada através de meios técnicos é limitada e está apoiada por procedimentos e gerenciamentos apropriados. A identificação de quais controles devem ser implementados requer planejamento e atenção cuidadosa em nível de detalhes. Um sistema de gestão da segurança da informação bem-sucedido requer apoio de todos os funcionários da organização.

Isto pode também exigir a participação de acionistas, fornecedores ou outras partes externas. Orientações de especialistas externos podem também ser necessárias. De um modo geral, uma segurança da informação eficaz também garante à direção e outras partes interessadas que os ativos da organização estão razoavelmente seguros e protegidos contra danos, agindo como um facilitador dos negócios.

11225354498 - Maria Vitória Gonçalves Vieira



É essencial que uma organização identifique os seus requisitos de segurança da informação. Existem três fontes principais de requisitos de segurança da informação:

FONTES PRINCIPAIS DE REQUISITOS DE SEGURANÇA DA INFORMAÇÃO

Uma fonte é obtida a partir da avaliação de riscos para a organização, levando-se em conta os objetivos e as estratégias globais de negócio da organização. Por meio da avaliação de riscos, são identificadas as ameaças aos ativos, e as vulnerabilidades destes e realizada uma estimativa da probabilidade de ocorrência das ameaças e do impacto potencial ao negócio.

Uma outra fonte é a legislação vigente, os estatutos, a regulamentação e as cláusulas contratuais que a organização, seus parceiros comerciais, contratados e provedores de serviço têm que atender, além do seu ambiente sociocultural.

A terceira fonte são os conjuntos particulares de princípios, objetivos e os requisitos do negócio para o manuseio, processamento, armazenamento, comunicação e arquivo da informação, que uma organização tem que desenvolver para apoiar suas operações.

Os recursos empregados na implementação dos controles precisam ser balanceados com base na probabilidade de danos ao negócio, resultado dos problemas de segurança pela ausência desses controles. Os resultados de uma avaliação de risco ajudarão a orientar e determinar as ações de gestão apropriadas e as prioridades para gerenciar os riscos de

11225354498 - Maria Vitória Gonçalves Vieira

segurança da informação e a implementação dos controles selecionados para proteger contra estes riscos.

A ABNT NBR ISO/IEC 27005 fornece diretrizes sobre gestão de riscos de segurança da informação, incluindo orientações sobre avaliação de riscos, tratamentos de riscos, aceitação de riscos, comunicação de riscos, monitoramento e análise crítica dos riscos. *E sobre os controles?* Controles podem ser selecionados desta norma ou de outros conjuntos de controles, ou novos controles podem ser projetados para atender necessidades especificas, conforme apropriado.

A seleção de controles de segurança da informação depende das decisões da organização, baseadas nos critérios para aceitação de risco, nas opções para tratamento do risco e no enfoque geral da gestão de risco aplicado à organização, e convém que também esteja sujeito a todas as legislações e regulamentações nacionais e internacionais, relevantes. A seleção de controles também depende da maneira pela qual os controles interagem para prover uma proteção segura.

Alguns dos controles nesta norma podem ser considerados como princípios básicos para a gestão da segurança da informação e podem ser aplicados na maioria das organizações. Esta Norma pode ser considerada como um ponto de partida para o desenvolvimento de diretrizes específicas para a organização. Nem todos os controles e diretrizes contidos neste código de prática podem ser aplicados. Controles adicionais e recomendações não incluídas nesta norma podem ser necessários.

Quando os documentos são desenvolvidos contendo controles ou recomendações adicionais, pode ser útil realizar uma referência cruzada com as seções desta norma, onde aplicável, para facilitar a verificação da conformidade por auditores e parceiros de negócio. É importante falar também sobre ciclo de vida: A informação tem um ciclo de vida natural, desde a sua criação e origem, armazenagem, processamento, uso e transmissão, até a sua eventual destruição ou obsolescência.

O valor e os riscos aos ativos podem variar durante o tempo de vida da informação (Ex: revelação não autorizada ou roubo de balanços financeiros de uma companhia, é muito menos importante depois que elas são formalmente publicadas), porém a segurança da informação permanece importante em algumas etapas de todos os estágios. Sistemas de Informação têm ciclos de vida nos quais eles são concebidos, especificados, projetados, desenvolvidos, testados, implementados, usados, mantidos e, eventualmente, retirados do serviço e descartados.

Convém que a segurança da informação seja considerada em cada estágio. Desenvolvimentos de sistemas novos e mudanças nos sistemas existentes são oportunidades para as organizações atualizarem e melhorarem os controles de segurança, levando em conta os

11225354498 - Maria Vitória Gonçalves Vieira

incidentes reais e os riscos de segurança da informação, projetados e atuais. Bem, essa norma fornece diretrizes para práticas de gestão de segurança da informação e normas de segurança da informação para as organizações, incluindo a seleção, implementação e o gerenciamento de controles, levando em consideração os ambientes de risco da segurança da informação da organização.

Esta norma é projetada para ser usada por organizações que pretendam: (a) selecionar controles dentro do processo de implementação de um sistema de gestão da segurança da informação baseado na ABNT NBR ISO/IEC 27001; (b) b) implementar controles de segurança da informação comumente aceitos; (c) desenvolver seus próprios princípios de gestão da segurança da informação.

Requisitos do SGSI

A norma está estruturada da seguinte forma:

a) Controles organizacionais (Seção 5).

b) Controles de pessoas (Seção 6).

c) Controles físicos (Seção 7).

d) Controles tecnológicos (Seção 8).

A categorização dos controles dados nas Seções 5 a 8 é referida como temas. Os controles são categorizados como:

a) pessoas, se eles dizem respeito a pessoas individuais;

b) físico, se eles dizem respeito a objetos físicos;

c) tecnológico, se eles dizem respeito à tecnologia;

d) caso contrário, eles são categorizados como organizacionais.

A organização pode usar atributos para criar diferentes visões que são categorizações diferentes dos controles, vistas de uma perspectiva diferente dos temas. Atributos podem

11225354498 - Maria Vitória Gonçalves Vieira

ser usados para filtrar, classificar ou apresentar controles em diferentes pontos de vista para diferentes públicos.

Controles Organizacionais (Seção 5)

5.1 Políticas de segurança da informação

Controle

Convém que a política de segurança da informação e as políticas específicas por tema sejam definidas, aprovadas pela direção, publicadas, comunicadas e reconhecidas pelo pessoal pertinente e partes interessadas pertinentes, e analisadas criticamente em intervalos planejados e se ocorrer mudanças significativas.

Propósito

Assegurar a adequação contínua, suficiência, efetividade da direção de gestão e suporte à segurança da informação de acordo com os requisitos comerciais, legais, estatutários, regulamentares e contratuais.

5.2 Papéis e responsabilidades pela segurança da informação

Controle

Convém que os papéis e responsabilidades pela segurança da informação sejam definidos e alocados de acordo com as necessidades da organização.

Propósito

Estabelecer uma estrutura definida, aprovada e compreendida para a implementação, operação e gestão da segurança da informação dentro da organização.

5.3 Segregação de funções

Controle

Convém que funções conflitantes e áreas de responsabilidade sejam segregados.

Propósito

Reduzir o risco de fraude, erro e desvio de controles de segurança da informação.

11225354498 - Maria Vitória Gonçalves Vieira

5.4 Responsabilidades da direção

Controle

Convém que a direção requeira que todo o pessoal aplique a segurança da informação de acordo com a política de segurança da informação estabelecida, com as políticas específicas por tema e com os procedimentos da organização.

Propósito

Assegurar que a direção entenda seu papel na segurança da informação e realize ações com o objetivo de assegurar que todo o pessoal esteja ciente e cumpra suas responsabilidades pela segurança da informação.

5.5 Contato com autoridades

Controle

Convém que a organização estabeleça e mantenha contato com as autoridades relevantes.

Propósito

Assegurar o fluxo adequado de informações referentes à segurança da informação entre a organização e as autoridades legais, regulatórias e fiscalizadoras relevantes.

5.6 Contato com grupos de interesse especial

Controle

Convém que a organização estabeleça e mantenha contato com grupos de interesse especial ou outros fóruns de especialistas em segurança e associações profissionais.

Propósito

Assegurar que ocorra o fluxo adequado de informações relacionadas à segurança da informação.

5.7 Inteligência de ameaças

Controle

Convém que as informações relacionadas a ameaças à segurança da informação sejam coletadas e analisadas para produzir inteligência de ameaças.

11225354498 - Maria Vitória Gonçalves Vieira

Propósito

Conscientizar sobre o ambiente de ameaças da organização para que as ações de mitigação adequadas possam ser tomadas.

5.8 Segurança da informação no gerenciamento de projetos

Controle

Convém que a segurança da informação seja integrada ao gerenciamento de projetos.

Propósito

Assegurar que os riscos de segurança da informação relacionados a projetos e entregas sejam efetivamente abordados no gerenciamento de projetos durante todo o ciclo de vida do projeto.

5.9 Inventário de informações e outros ativos associados

Controle

Convém que um inventário de informações e outros ativos associados, incluindo proprietários, seja desenvolvido e mantido.

Propósito

Identificar as informações da organização e outros ativos associados, a fim de preservar a sua segurança da informação e atribuir a propriedade adequada.

5.10 Uso aceitável de informações e outros ativos associados

Controle

Convém que regras para o uso aceitável e procedimentos para o manuseio de informações e outros ativos associados sejam identificados, documentados e implementados.

Propósito

Assegurar que as informações e outros ativos associados sejam devidamente protegidos, usados e manuseados

5.11 Devolução de ativos

Controle

11225354498 - Maria Vitória Gonçalves Vieira

Convém que o pessoal e outras partes interessadas, conforme apropriado, devolvam todos os ativos da organização em sua posse após a mudança ou encerramento da contratação ou acordo.

Propósito

Proteger os ativos da organização como parte do processo de mudança ou encerramento da contratação ou acordo.

5.12 Classificação das informações

Controle

Convém que as informações sejam classificadas de acordo com as necessidades de segurança da informação da organização com base na confidencialidade, integridade, disponibilidade e requisitos relevantes das partes interessadas.

Propósito

Assegurar a identificação e o entendimento das necessidades de proteção das informações de acordo com a sua importância para a organização.

5.13 Rotulagem de informações

Controle

Convém que um conjunto adequado de procedimentos para rotulagem de informações seja desenvolvido e implementado de acordo com o esquema de classificação de informações adotado pela organização.

Propósito

Facilitar a comunicação da classificação das informações e apoio à automação da gestão e tratamento das informações.

5.14 Transferência de informações

Controle

Convém que regras, procedimentos ou acordos de transferência de informações sejam implementados para todos os tipos de recursos de transferência dentro da organização e entre a organização e outras partes.

11225354498 - Maria Vitória Gonçalves Vieira

Propósito

Manter a segurança das informações transferidas dentro de uma organização e com qualquer parte interessada externa.

5.15 Controle de acesso

Controle

Convém que as regras para controlar o acesso físico e lógico às informações e outros ativos associados sejam estabelecidas e implementadas com base nos requisitos de segurança da informação e de negócios.

Propósito

Assegurar o acesso autorizado e evitar o acesso não autorizado a informações e outros ativos associados.

5.16 Gestão de identidade

Controle

Convém que o ciclo de vida completo das identidades seja gerenciado.

Propósito

Permitir a identificação única de indivíduos e sistemas que acessam as informações da organização e outros ativos associados e para permitir a cessão adequada de direitos de acesso.

5.17 Informações de autenticação

Controle

Convém que a alocação e a gestão de informações de autenticação sejam controladas por uma gestão de processo, incluindo aconselhar o pessoal sobre o manuseio adequado de informações de autenticação.

Propósito

Assegurar a autenticação adequada da entidade e evitar falhas nos processos de autenticação.

11225354498 - Maria Vitória Gonçalves Vieira

5.18 Direitos de acesso

Controle

Convém que os direitos de acesso às informações e outros ativos associados sejam provisionados, analisados criticamente, modificados e removidos de acordo com a política de tema específico e regras da organização para o controle de acesso.

Propósito

Assegurar que o acesso às informações e outros ativos associados esteja definido e autorizado de acordo com os requisitos do negócio.

5.19 Segurança da informação nas relações com fornecedores

Controle

Convém que processos e procedimentos sejam definidos e implementados para gerenciar a segurança da informação e os riscos associados com o uso dos produtos ou serviços dos fornecedores.

Propósito

Manter um nível acordado de segurança da informação nas relações com fornecedores.

5.20 Abordagem da segurança da informação nos contratos de fornecedores

Controle

Convém que requisitos relevantes de segurança da informação sejam estabelecidos e acordados com cada fornecedor com base no tipo de relacionamento com o fornecedor.

Propósito

Manter um nível acordado de segurança da informação nas relações com fornecedores.

5.21 Gestão da segurança da informação na cadeia de fornecimento de TIC

Controle

Convém que processos e procedimentos sejam definidos e implementados para gerenciar riscos de segurança da informação associados à cadeia de fornecimento de produtos e serviços de TIC.

11225354498 - Maria Vitória Gonçalves Vieira

Propósito

Manter um nível acordado de segurança da informação nas relações com fornecedores.

5.22 Monitoramento, análise crítica e gestão de mudanças dos serviços de fornecedores

Controle

Convém que a organização monitore, analise criticamente, avalie e gerencie regularmente a mudança nas práticas de segurança da informação dos fornecedores e na prestação de serviços.

Propósito

Manter um nível acordado de segurança da informação e prestação de serviços em linha com os acordos com os fornecedores.

5.23 Segurança da informação para uso de serviços em nuvem

Controle

Convém que os processos de aquisição, uso, gestão e saída de serviços em nuvem sejam estabelecidos de acordo com os requisitos de segurança da informação da organização.

Propósito

Especificar e gerenciar a segurança da informação para o uso de serviços em nuvem.

5.24 Planejamento e preparação da gestão de incidentes de segurança da informação

Controle

Convém que a organização planeje e se prepare para gerenciar incidentes de segurança da informação definindo, estabelecendo e comunicando processos, papéis e responsabilidades de gestão de incidentes de segurança da informação.

Propósito

Assegurar uma resposta rápida, eficaz, consistente e ordenada aos incidentes de segurança da informação, incluindo a comunicação sobre eventos de segurança da informação.

5.25 Avaliação e decisão sobre eventos de segurança da informação

11225354498 - Maria Vitória Gonçalves Vieira

Controle

Convém que a organização avalie os eventos de segurança da informação e decida se categoriza como incidentes de segurança da informação.

Propósito

Assegurar a efetiva categorização e priorização de eventos de segurança da informação.

5.26 Resposta a incidentes de segurança da informação

Controle

Convém que os incidentes de segurança da informação sejam respondidos de acordo com os procedimentos documentados.

Propósito

Assegurar uma resposta eficiente e eficaz aos incidentes de segurança da informação.

5.27 Aprendizado com incidentes de segurança da informação

Controle

Convém que o conhecimento adquirido com incidentes de segurança da informação seja usado para fortalecer e melhorar os controles de segurança da informação.

Propósito

Reduzir a probabilidade ou as consequências de futuros incidentes.

5.28 Coleta de evidências

Controle

Convém que a organização estabeleça e implemente procedimentos para identificação, coleta, aquisição e preservação de evidências relacionadas a eventos de segurança da informação.

Propósito

Assegurar uma gestão consistente e eficaz das evidências relacionadas a incidentes de segurança da informação para fins de ações disciplinares e legais.

11225354498 - Maria Vitória Gonçalves Vieira

5.29 Segurança da informação durante a disrupção

Controle

Convém que a organização planeje como manter a segurança da informação em um nível apropriado durante a disrupção.

Propósito

Proteger as informações e outros ativos associados durante a disrupção.

5.30 Prontidão de TIC para continuidade de negócios

Controle

Convém que a prontidão da TIC seja planejada, implementada, mantida e testada com base nos objetivos de continuidade de negócios e nos requisitos de continuidade da TIC.

Propósito

Assegurar a disponibilidade das informações da organização e outros ativos associados durante a disrupção.

5.31 Requisitos legais, estatutários, regulamentares e contratuais

Controle

Convém que os requisitos legais, estatutários, regulamentares e contratuais pertinentes à segurança da informação e à abordagem da organização para atender a esses requisitos sejam identificados, documentados e atualizados.

Propósito

Assegurar o compliance dos requisitos legais, estatutários, regulamentares e contratuais relacionados à segurança da informação

5.32 Direitos de propriedade intelectual

Controle

Convém que a organização implemente procedimentos adequados para proteger os direitos de propriedade intelectual.

Propósito

11225354498 - Maria Vitória Gonçalves Vieira

Assegurar o compliance dos requisitos legais, estatutários, regulamentares e contratuais relacionados aos direitos de propriedade intelectual e ao uso de produtos proprietários.

5.33 Proteção de registros

Controle

Convém que os registros sejam protegidos contra perdas, destruição, falsificação, acesso não autorizado e liberação não autorizada.

Propósito

Assegurar o compliance dos requisitos legais, estatutários, regulamentares e contratuais, bem como expectativas comunitárias ou sociais relacionadas à proteção e disponibilidade de registros.

5.34 Privacidade e proteção de DP

Controle

Convém que a organização identifique e atenda aos requisitos relativos à preservação da privacidade e proteção de DP de acordo com as leis e regulamentos aplicáveis e requisitos contratuais.

Propósito

Assegurar o compliance dos requisitos legais, estatutários, regulamentares e contratuais relacionados aos aspectos de segurança da informação da proteção de DP.

5.35 Análise crítica independente da segurança da informação

Controle

Convém que a abordagem da organização para gerenciar a segurança da informação e sua

implementação, incluindo pessoas, processos e tecnologias, seja analisada criticamente de forma independente a intervalos planejados ou quando ocorrem mudanças significativas.

Propósito

Assegurar a contínua adequação, suficiência e eficácia da abordagem da organização para a gestão da segurança da informação.

11225354498 - Maria Vitória Gonçalves Vieira

5.36 Conformidade com políticas, regras e normas para segurança da informação

Controle

Convém que o compliance da política de segurança da informação da organização, políticas, regras e normas de temas específicos seja analisado criticamente a intervalos regulares.

Propósito

Assegurar que a segurança da informação seja implementada e operada de acordo com a política de segurança da informação da organização, políticas, regras e normas específicas por tema.

5.37 Documentação dos procedimentos de operação

Controle

Convém que os procedimentos de operação dos recursos de tratamento da informação sejam documentados e disponibilizados para o pessoal que necessite deles.

Propósito

Assegurar a operação correta e segura dos recursos de tratamento da informação.

Controles de Pessoas (Seção 6)

6.1 Seleção

Controle

Convém que verificações de antecedentes de todos os candidatos a serem contratados sejam realizadas antes de ingressarem na organização e de modo contínuo, de acordo com as leis, regulamentos e ética aplicáveis e que sejam proporcionais aos requisitos do negócio, à classificação das informações a serem acessadas e aos riscos percebidos.

Propósito

Assegurar que todo o pessoal seja elegível e adequado para os papéis para os quais são considerados e permaneça elegível e adequado durante sua contratação.

6.2 Termos e condições de contratação

11225354498 - Maria Vitória Gonçalves Vieira

Controle

Convém que os contratos trabalhistas declarem as responsabilidades do pessoal e da organização para a segurança da informação.

Propósito

Assegurar que o pessoal entenda suas responsabilidades de segurança da informação para os papéis para os quais eles são considerados.

6.3 Conscientização, educação e treinamento em segurança da informação

Controle

Convém que o pessoal da organização e partes interessadas relevantes recebam treinamento, educação e conscientização em segurança da informação apropriados e atualizações regulares da política de segurança da informação da organização, políticas e procedimentos específicas por tema, pertinentes para as suas funções.

Propósito

Assegurar que o pessoal e as partes interessadas pertinentes estejam cientes e cumpram suas responsabilidades de segurança da informação.

6.4 Processo disciplinar

Controle

Convém que um processo disciplinar seja formalizado e comunicado, para tomar ações contra pessoal e outras partes interessadas relevantes que tenham cometido uma violação da política de segurança da informação.

Propósito

Assegurar que o pessoal e outras partes interessadas pertinentes entendam as consequências da violação da política de segurança da informação, para dissuadir e lidar adequadamente com as pessoas que cometeram a violação.

6.5 Responsabilidades após encerramento ou mudança da contratação

Controle

11225354498 - Maria Vitória Gonçalves Vieira

Convém que as responsabilidades e funções de segurança da informação que permaneçam válidos após o encerramento ou mudança da contratação sejam definidos, aplicados e comunicados ao pessoal e outras partes interessadas pertinentes.

Propósito

Proteger os interesses da organização como parte do processo de mudança ou encerramento da contratação ou de um contrato.

6.6 Acordos de confidencialidade ou não divulgação

Controle

Convém que acordos de confidencialidade ou não divulgação que reflitam as necessidades da organização para a proteção das informações sejam identificados, documentados, analisados criticamente em intervalos regulares e assinados por pessoal e outras partes interessadas pertinentes.

Propósito

Manter a confidencialidade das informações acessíveis pelo pessoal ou por partes externas.

6.7 Trabalho remoto

Controle

Convém que medidas de segurança sejam implementadas quando as pessoas estiverem trabalhando remotamente para proteger as informações acessadas, tratadas ou armazenadas fora das instalações da organização.

Propósito

Assegurar a segurança das informações quando o pessoal estiver trabalhando remotamente.

6.8 Relato de eventos de segurança da informação

Controle

Convém que a organização forneça um mecanismo para que as pessoas relatem eventos de segurança da informação observados ou suspeitos através de canais apropriados em tempo hábil.

Propósito

11225354498 - Maria Vitória Gonçalves Vieira

Oferecer apoio em tempo hábil a relatos, consistentes e eficazes de eventos de segurança da informação que podem ser identificados pelo pessoal.

Controles Físicos (Seção 7)

7.1 Perímetros de segurança física

Controle

Convém que perímetros de segurança sejam definidos e usados para proteger áreas que contenham informações e outros ativos associados.

Propósito

Evitar acesso físico não autorizado, danos e interferências nas informações da organização e outros ativos associados.

7.2 Entrada física

Controle

Convém que as áreas seguras sejam protegidas por controles de entrada e pontos de acesso apropriados.

Propósito

Assegurar que ocorra apenas acesso físico autorizado às informações da organização e outros ativos associados.

7.3 Segurança de escritórios, salas e instalações

Controle

Convém que seja projetada e implementada segurança física para escritórios, salas e instalações.

Propósito

Evitar acesso físico não autorizado, danos e interferências nas informações da organização e outros ativos associados em escritórios, salas e instalações.

11225354498 - Maria Vitória Gonçalves Vieira

7.4 Monitoramento de segurança física

Controle

Convém que as instalações sejam monitoradas continuamente para acesso físico não autorizado.

Propósito

Detectar e impedir o acesso físico não autorizado.

7.5 Proteção contra ameaças físicas e ambientais

Controle

Convém que a proteção contra ameaças físicas e ambientais, como desastres naturais e outras ameaças físicas intencionais ou não intencionais à infraestrutura, seja projetada e implementada.

Propósito

Prevenir ou reduzir as consequências de eventos originários de ameaças físicas e ambientais.

7.6 Trabalho em áreas seguras

Controle

Convém que medidas de segurança para trabalhar em áreas seguras sejam projetadas e implementadas.

Propósito

Proteger as informações e outros ativos associados em áreas seguras contra danos e interferência não autorizada do pessoal que trabalha nessas áreas.

7.7 Mesa limpa e tela limpa

Controle

Convém que regras de mesa limpa para documentos impressos e mídia de armazenamento removível e regras de tela limpa para os recursos de tratamento das informações sejam definidas e adequadamente aplicadas.

Propósito

11225354498 - Maria Vitória Gonçalves Vieira

Reduzir os riscos de acesso não autorizado, perda e danos às informações em mesas, telas e em outros locais acessíveis durante e fora do horário comercial.

7.8 Localização e proteção de equipamentos

Controle

Convém que os equipamentos sejam posicionados com segurança e proteção.

Propósito

Reduzir os riscos de ameaças físicas e ambientais, e de acesso não autorizado e danos.

7.9 Segurança de ativos fora das instalações da organização

Controle

Convém proteger os ativos fora das instalações da organização.

Propósito

Evitar perdas, danos, roubos ou comprometimento de ativos fora das instalações da organização e interrupção da operação da organização.

7.10 Mídia de armazenamento

Controle

Convém que as mídias de armazenamento sejam gerenciadas por seu ciclo de vida de aquisição, uso, transporte e descarte, de acordo com o esquema de classificação e com os requisitos de manuseio da organização.

Propósito

Assegurar a divulgação, modificação, remoção ou destruição de informações apenas de forma autorizada sobre as mídias de armazenamento.

7.11 Serviços de infraestrutura

Controle

Convém que as instalações de tratamento de informações sejam protegidas contra falhas de energia e outras disrupções causadas por falhas nos serviços de infraestrutura.

11225354498 - Maria Vitória Gonçalves Vieira

Propósito

Evitar perdas, danos ou comprometimento de informações e outros ativos associados, ou a interrupção das operações da organização devido à falha e disrupção nos serviços de infraestrutura.

7.12 Segurança do cabeamento

Controle

Convém que os cabos que transportam energia ou dados ou que sustentam serviços de informação sejam protegidos contra interceptação, interferência ou danos.

Propósito

Evitar perdas, danos, roubo ou comprometimento de informações e outros ativos associados à interrupção das operações da organização relacionadas ao cabeamento de energia e de comunicação.

7.13 Manutenção de equipamentos

Controle

Convém que os equipamentos sejam mantidos corretamente para assegurar a disponibilidade, integridade e confidencialidade da informação.

Propósito

Evitar perdas, danos, roubos ou comprometimento de informações e outros ativos associados e interrupção das operações da organização causada pela falta de manutenção.

7.14 Descarte seguro ou reutilização de equipamentos

Controle

Convém que sejam verificados os itens dos equipamentos que contenham mídia de armazenamento, para assegurar que quaisquer dados confidenciais e software licenciado tenham sido removidos ou substituídos com segurança antes do descarte ou reutilização.

Propósito

Evitar o vazamento de informações por equipamento que seja descartado ou reutilizado.

11225354498 - Maria Vitória Gonçalves Vieira

Controles Tecnológicos (Seção 8)

8.1 Dispositivos endpoint do usuário

Controle

Convém que as informações armazenadas, tratadas ou acessíveis por meio de dispositivos endpoint do usuário sejam protegidas.

Propósito

Proteger informações contra os riscos introduzidos pelo uso de dispositivos endpoint do usuário.

8.2 Direitos de acessos privilegiados

Controle

Convém restringir e gerenciar a atribuição e o uso de direitos de acessos privilegiados.

Propósito

Assegurar que apenas usuários, componentes de software e serviços autorizados recebam direitos de acessos privilegiados.

8.3 Restrição de acesso à informação

Controle

Convém que o acesso às informações e outros ativos associados seja restrito de acordo com a política específica por tema sobre controle de acesso.

Propósito

Assegurar apenas o acesso autorizado e impedir o acesso não autorizado a informações e a outros ativos associados.

8.4 Acesso ao código-fonte

Controle

11225354498 - Maria Vitória Gonçalves Vieira

Convém que os acessos de leitura e escrita ao código-fonte, ferramentas de desenvolvimento e bibliotecas de software sejam adequadamente gerenciados.

Propósito

Evitar a introdução de funcionalidades não autorizadas, prevenir mudanças não intencionais ou maliciosas e manter a confidencialidade de propriedade intelectual valiosa.

8.5 Autenticação segura

Controle

Convém que sejam implementadas tecnologias e procedimentos de autenticação seguros, com base em restrições de acesso à informação e à política específica por tema de controle de acesso.

Propósito

Assegurar que um usuário ou uma entidade seja autenticada com segurança, quando o acesso a sistemas, aplicações e serviços é concedido.

8.6 Gestão de capacidade

Controle

Convém que o uso dos recursos seja monitorado e ajustado de acordo com os requisitos atuais e esperados de capacidade.

Propósito

Assegurar a capacidade necessária dos recursos de tratamento de informações, recursos humanos, escritórios e outros serviços de infraestrutura.

8.7 Proteção contra malware

Controle

Convém que a proteção contra malware seja implementada e apoiada pela conscientização adequada do usuário.

Propósito

Assegurar que informações e outros ativos associados estejam protegidos contra malware.

11225354498 - Maria Vitória Gonçalves Vieira

8.8 Gestão de vulnerabilidades técnicas

Controle

Convém que informações sobre vulnerabilidades técnicas dos sistemas de informação em uso sejam obtidas, a exposição da organização a tais vulnerabilidades sejam avaliadas e medidas apropriadas sejam tomadas.

Propósito

Evitar a exploração de vulnerabilidades técnicas.

8.9 Gestão de configuração

Controle

Convém que as configurações, incluindo configurações de segurança, de hardware, software, serviços e redes sejam estabelecidas, documentadas, implementadas, monitoradas e analisadas criticamente.

Propósito

Assegurar que o hardware, o software, os serviços e as redes funcionem corretamente com as configurações de segurança necessárias, e que a configuração não seja alterada por alterações não autorizadas ou incorretas.

8.10 Exclusão de informações

Controle

Convém que as informações armazenadas em sistemas de informação, dispositivos ou em qualquer outra mídia de armazenamento sejam excluídas quando não forem mais necessárias.

Propósito

Evitar a exposição desnecessária de informações sensíveis e estar em compliance com requisitos legais, estatutários, regulamentares e contratuais para a exclusão de informações.

8.11 Mascaramento de dados

Controle

11225354498 - Maria Vitória Gonçalves Vieira

Convém que o mascaramento de dados seja usado de acordo com a política específica por tema da organização sobre controle de acesso e outros requisitos específicos por tema relacionados e requisitos de negócios, levando em consideração a legislação aplicável.

Propósito

Limitar a exposição de dados confidenciais, incluindo DP, e cumprir requisitos legais, estatutários, regulamentares e contratuais.

8.12 Prevenção de vazamento de dados

Controle

Convém que medidas de prevenção de vazamento de dados sejam aplicadas a sistemas, redes e quaisquer outros dispositivos que tratem, armazenem ou transmitam informações sensíveis.

Propósito

Detectar e prevenir a divulgação e extração não autorizadas de informações por indivíduos ou sistemas.

8.13 Backup das informações

Controle

Convém que cópias de backup de informações, software e sistemas sejam mantidas e testadas regularmente de acordo com a política específica por tema acordada sobre backup.

Propósito

Permitir a recuperação da perda de dados ou sistemas.

8.14 Redundância dos recursos de tratamento de informações

Controle

Convém que os recursos de tratamento de informações sejam implementados com redundância suficiente para atender aos requisitos de disponibilidade.

Propósito

Assegurar o funcionamento contínuo dos recursos de tratamento de informações.

11225354498 - Maria Vitória Gonçalves Vieira

8.15 Log

Controle

Convém que logs que registrem atividades, exceções, falhas e outros eventos relevantes sejam produzidos, armazenados, protegidos e analisados.

Propósito

Registrar eventos, gerar evidências, assegurar a integridade das informações de registro, prevenir contra acesso não autorizado, identificar eventos de segurança da informação que possam levar a um incidente de segurança da informação e apoiar investigações.

8.16 Atividades de monitoramento

Controle

Convém que redes, sistemas e aplicações sejam monitorados por comportamentos anômalos e por ações apropriadas, tomadas para avaliar possíveis incidentes de segurança da informação.

Propósito

Detectar comportamentos anômalos e possíveis incidentes de segurança da informação.

8.17 Sincronização do relógio

Controle

Convém que os relógios dos sistemas de tratamento de informações utilizados pela organização sejam sincronizados com fontes de tempo aprovadas.

Propósito

Permitir a correlação e a análise de eventos relacionadas à segurança e a outros dados registrados, e apoiar investigações sobre incidentes de segurança da informação.

8.18 Uso de programas utilitários privilegiados

Controle

Convém que o uso de programas utilitários que possam ser capazes de substituir os controles de sistema e aplicações seja restrito e rigorosamente controlado.

11225354498 - Maria Vitória Gonçalves Vieira

Propósito

Assegurar que o uso de programas utilitários não prejudique os controles do sistema e das aplicações para a segurança da informação.

8.19 Instalação de software em sistemas operacionais

Controle

Convém que procedimentos e medidas sejam implementados para gerenciar com segurança a instalação de software em sistemas operacionais.

Propósito

Assegurar a integridade dos sistemas operacionais e evitar a exploração de vulnerabilidades técnicas.

8.20 Segurança de redes

Controle

Convém que redes e dispositivos de rede sejam protegidos, gerenciados e controlados para proteger as informações em sistemas e aplicações.

Propósito

Proteger as informações nas redes e seus recursos de tratamento de informações de suporte contra o comprometimento por rede.

8.21 Segurança dos serviços de rede

Controle

Convém que sejam identificados, implementados e monitorados mecanismos de segurança, níveis de serviço e requisitos de serviços de rede.

Propósito

Assegurar a segurança no uso de serviços de rede.

8.22 Segregação de redes

Controle

11225354498 - Maria Vitória Gonçalves Vieira

Convém que grupos de serviços de informação, usuários e sistemas de informação sejam segregados nas redes da organização.

Propósito

Dividir a rede em perímetros de segurança e controlar o tráfego entre eles com base nas necessidades de negócios.

8.23 Filtragem da web

Controle

Convém que o acesso a sites externos seja gerenciado para reduzir a exposição a conteúdo malicioso.

Propósito

Proteger os sistemas de serem comprometidos por malware e impedir o acesso a recursos web não autorizados.

8.24 Uso de criptografia

Controle

Convém que sejam definidas e implementadas regras para o uso efetivo da criptografia, incluindo o gerenciamento de chaves criptográficas.

Propósito

Assegurar o uso adequado e eficaz da criptografia para proteger a confidencialidade, autenticidade ou integridade das informações de acordo com os requisitos de segurança das empresas e da informação, e levando em consideração os requisitos legais, estatutários, regulamentares e contratuais relacionados à criptografia.

8.25 Ciclo de vida de desenvolvimento seguro

Controle

Convém que regras para o desenvolvimento seguro de software e sistemas sejam estabelecidas e aplicadas.

Propósito

11225354498 - Maria Vitória Gonçalves Vieira

Assegurar que a segurança da informação seja projetada e implementada dentro do ciclo de vida de desenvolvimento seguro de software e sistemas.

8.26 Requisitos de segurança da aplicação

Controle

Convém que os requisitos de segurança da informação sejam identificados, especificados e aprovados ao desenvolver ou adquirir aplicações.

Propósito

Assegurar que todos os requisitos de segurança da informação sejam identificados e abordados ao desenvolver ou adquirir aplicações.

8.27 Princípios de arquitetura e engenharia de sistemas seguros

Controle

Convém que princípios de engenharia para sistemas de segurança sejam estabelecidos, documentados, mantidos e aplicados a qualquer atividade de desenvolvimento de sistemas.

Propósito

Assegurar que os sistemas de informação sejam projetados, implementados e operados com segurança dentro do ciclo de vida de desenvolvimento.

8.28 Codificação segura

Controle

Convém que princípios de codificação segura sejam aplicados ao desenvolvimento de software.

Propósito

Assegurar que o software seja escrito com segurança, reduzindo assim o número de potenciais vulnerabilidades de segurança da informação no software.

8.29 Testes de segurança em desenvolvimento e aceitação

Controle

11225354498 - Maria Vitória Gonçalves Vieira

Convém que os processos de teste de segurança sejam definidos e implementados no ciclo de vida do desenvolvimento.

Propósito

Validar se os requisitos de segurança da informação são atendidos quando as aplicações ou códigos são implantados no ambiente de produção.

8.30 Desenvolvimento terceirizado

Controle

Convém que a organização dirija, monitore e analise criticamente as atividades relacionadas à terceirização de desenvolvimento de sistemas.

Propósito

Assegurar que as medidas de segurança da informação requeridas pela organização sejam implementadas na terceirização do desenvolvimento de sistemas.

8.31 Separação dos ambientes de desenvolvimento, teste e produção

Controle

Convém que ambientes de desenvolvimento, testes e produção sejam separados e protegidos.

Propósito

Proteger o ambiente de produção e os dados de comprometimento por meio de atividades de desenvolvimento e teste.

8.32 Gestão de mudanças

Controle

Convém que mudanças nos recursos de tratamento de informações e sistemas de informação estejam sujeitas a procedimentos de gestão de mudanças.

Propósito

Preservar a segurança da informação ao executar mudanças.

8.33 Informações de teste

11225354498 - Maria Vitória Gonçalves Vieira

Controle

Convém que as informações de teste sejam adequadamente selecionadas, protegidas e gerenciadas.

Propósito

Assegurar a relevância dos testes e a proteção das informações operacionais utilizadas para testes.

8.34 Proteção de sistemas de informação durante os testes de auditoria

Controle

Convém que testes de auditoria e outras atividades de garantia envolvendo a avaliação de sistemas operacionais sejam planejados e acordados entre o testador e a gestão apropriada.

Propósito

Minimizar o impacto da auditoria e outras atividades de garantia em sistemas operacionais e processos de negócio.

APOSTA ESTRATÉGICA

A ideia desta seção é apresentar os pontos do conteúdo que mais possuem chances de serem cobrados em prova, considerando o histórico de questões da banca em provas de nível semelhante à nossa, bem como as inovações no conteúdo, na legislação e nos entendimentos doutrinários e jurisprudenciais[1].

Um aspecto técnico significativo abordado pela ISO 27002 é a implementação de controles de acesso para proteger informações sensíveis e ativos de informação. Esses controles são projetados para garantir que apenas usuários autorizados tenham acesso a sistemas, aplicações e dados específicos, baseando-se no princípio de menor privilégio. Isso significa que os usuários são concedidos apenas os direitos de acesso que são estritamente necessários para realizar suas tarefas.

[1] Vale deixar claro que nem sempre será possível realizar uma aposta estratégica para um determinado assunto, considerando que às vezes não é viável identificar os pontos mais prováveis de serem cobrados a partir de critérios objetivos ou minimamente razoáveis.

11225354498 - Maria Vitória Gonçalves Vieira

Os controles de acesso abrangem várias técnicas e tecnologias, incluindo autenticação multifatorial, gestão de identidades e atributos, e o uso de listas de controle de acesso (ACLs) para definir permissões detalhadas. Esses mecanismos são vitais para prevenir acessos não autorizados e potenciais violações de dados, representando uma linha de defesa fundamental na proteção dos ativos informacionais de uma organização.

QUESTÕES ESTRATÉGICAS

Nesta seção, apresentamos e comentamos uma amostra de questões objetivas selecionadas estrategicamente: são questões com nível de dificuldade semelhante ao que você deve esperar para a sua prova e que, em conjunto, abordam os principais pontos do assunto.

A ideia, aqui, não é que você fixe o conteúdo por meio de uma bateria extensa de questões, mas que você faça uma boa revisão global do assunto a partir de, relativamente, poucas questões.

1. **(VUNESP / Câmara de Tatuí – SP – 2019)** A Norma NBR ISO/IEC 27002 (Tecnologia da Informação – Técnicas de segurança – Código de Prática para controles de segurança da informação) contém, em uma de suas seções, recomendações sobre o tratamento de mídias utilizadas para o armazenamento de informações da empresa. Tais recomendações, no que diz respeito ao tratamento dessas mídias, incluem:

a) a aplicação de multas e a definição dos tipos de mídias utilizadas.

b) a definição dos responsáveis e o descarte das mídias utilizadas.

c) a definição do local de armazenamento e o tipo de formatação das mídias utilizadas.

d) o descarte e a transferência física das mídias utilizadas.

e) o tipo de formatação e a definição dos responsáveis pelas mídias utilizadas.

Comentários:

(a) Errado, não há menções a multas na norma; (b) Errado, não há definição de responsáveis na norma – a norma diz que convém que as mídias sejam descartadas de forma segura, quando não forem mais necessárias, por meio de procedimentos formais; (c) Errado, não há definição do local de armazenamento e o tipo de formatação das mídias utilizadas na norma; (d) Correto, a norma traz 8.3.2 – Descarte de Mídias e 8.3.3 – Transferência Física de Mídias; (e) Errado, nenhum dos dois é mencionado pela norma.

Gabarito: Letra D

2. **(FGV / MPE-AL – 2018)** Janaína pretende padronizar seus procedimentos de controle de acesso, com base na norma ISO 27002. A parte referente ao controle de acesso privilegiado cita, de forma geral, que o acesso deve ser restrito e controlado e que se institua um processo formal de concessão de privilégios. Para que Janaína implemente o controle de acesso privilegiado convém considerar que:

a) os direitos de acesso privilegiados, associados a cada sistema ou processo, por exemplo, sistema operacional, sistemas de gerenciamento de banco de dados e cada aplicação, e de categorias de usuários para os quais estes necessitam ser concedidos, não precisam de identificação.

b) os direitos de acesso privilegiado sejam concedidos a usuários conforme o grau hierárquico na empresa e com base em eventos alinhados com a política de controle de acesso, com base nos requisitos mínimos para sua função.

c) um processo de autorização e um registro de todos os privilégios concedidos sejam mantidos e que os direitos de acesso privilegiados não sejam concedidos até que todo o processo de autorização esteja finalizado.

d) requisitos para manter, sem atualização, os direitos de acesso privilegiados sejam definidos.

e) os direitos de acesso privilegiados sejam atribuídos a um ID de usuário idêntico daqueles usados nas atividades normais do negócio e que as atividades normais do negócio não sejam desempenhadas usando contas privilegiadas.

Comentários:

(a) Errado. Convém que os seguintes passos sejam considerados: (a) os direitos de acesso privilegiados, associados a cada sistema ou processo, por exemplo, sistema operacional, sistemas de gerenciamento de banco de dados e cada aplicação, e de categorias de usuários para os quais estes necessitam ser concedido, sejam identificados;

11225354498 - Maria Vitória Gonçalves Vieira

(b) Errado. Convém que os seguintes passos sejam considerados: (b) os direitos de acesso privilegiado sejam concedidos a usuários conforme a necessidade de uso e com base em eventos alinhados com a política de controle de acesso, baseado nos requisitos mínimos para sua função;

(c) Correto. Convém que os seguintes passos sejam considerados: (c) um processo de autorização e um registro de todos os privilégios concedidos sejam mantidos. Direitos de acesso privilegiados não sejam concedidos até que todo o processo de autorização esteja finalizado;

(d) Errado. Convém que os seguintes passos sejam considerados: (d) requisitos para expirar os direitos de acesso privilegiado sejam definidos;

(e) Errado. Convém que os seguintes passos sejam considerados: os direitos de acesso privilegiados sejam atribuídos a um ID de usuário diferente daqueles usados nas atividades normais do negócio. As atividades normais do negócio não sejam desempenhadas usando contas privilegiadas.

Gabarito: Letra C

3. **(FGV / MPE-AL – 2018)** Uma das seções de controle de segurança da informação é a Segurança em Recursos Humanos. Ela busca assegurar, dentre outros objetivos, que os funcionários e as partes externas estejam conscientes e cumpram suas responsabilidades pela segurança da informação.

   De acordo com a ABNT NBR ISO/IEC 27002:2013, seção Segurança em Recursos Humanos, durante a contratação convém implementar o controle:

   a) do processo disciplinar.

   b) do acesso ao código-fonte de programas.

   c) dos registros de eventos (log) de administrador e operador.

   d) do gerenciamento de mídias removíveis.

   e) do proprietário dos ativos

   Comentários:

   (a) Correto; (b) Errado, esse é um controle relacionado ao Acesso ao Sistema e à Aplicação; (c) Errado, esse é um controle relacionado a Registros e Monitoramento; (d) Errado, esse é

11225354498 - Maria Vitória Gonçalves Vieira

um controle relacionado ao Tratamento de Mídias; (e) Errado, esse é um controle relacionado à Responsabilidade pelos Ativos;

Gabarito: Letra A

4. **(FGV / Banestes – 2018)** Dentro de uma política de desenvolvimento seguro, a norma ABNT NBR ISO/IEC 27002:2013 recomenda que:

a) os aspectos de segurança sejam observados principalmente na fase de programação;

b) o desenvolvimento de software seja sempre executado por equipes internas;

c) todas as conexões não autenticadas devam ser criptografadas;

d) seja levada em consideração a segurança no controle de versões;

e) sejam previstos dois roteiros, um com foco em desenvolvimento e outro com foco em manutenção.

Comentários:

(a) Errado, isso não é mencionado na norma em nenhum momento; (b) Errado, isso não é mencionado na norma em nenhum momento; (c) Errado, isso não é mencionado na norma em nenhum momento; (d) Correto. Dentro de uma política de desenvolvimento seguro, convém que os seguintes aspectos sejam considerados: segurança no controle de versões; (e) Errado, isso não é mencionado na norma em nenhum momento.

Gabarito: Letra D

5. **(FGV / Câmara de Salvador - BA – 2018)** Um profissional de segurança da informação deve compreender detalhadamente a norma NBR ISO/IEC 27002 para aplicá-la corretamente na sua organização. Sobre o tema, analise as afirmativas a seguir.

I. A norma foi originalmente publicada como NBR ISO/IEC 27001, sendo atualizada com o objetivo de fornecer recomendações básicas e mínimas para a gestão de segurança da informação nas organizações.

II. Para que o processo de segurança da informação de uma organização tenho sucesso, é necessário que os regulamentos estejam alinhados com os objetivos do negócio e a forma de implementação seja coerente com a cultura organizacional.

11225354498 - Maria Vitória Gonçalves Vieira

III. Para proteger adequadamente a informação, é necessário que se tenha a identificação dos ativos de informação, seus responsáveis, sua forma de uso e classificação em termos de sigilo.

Está correto somente o que se afirma em:

a) I;

b) II;

c) III;

d) I e II;

e) II e III.

Comentários:

(I) Errado. Na verdade, elas são normas complementares; (II) Correto. De acordo com a norma, a segurança da informação é alcançada pela implementação de um conjunto adequado de controles, incluindo políticas, processos, procedimentos, estrutura organizacional e funções de software e hardware. Estes controles precisam ser estabelecidos, implementados, monitorados, analisados criticamente e melhorados, quando necessário, para assegurar que os objetivos do negócio e a segurança da informação da organização são atendidos; (III) Correto. De acordo com a norma, convém que os ativos associados com informação e com os recursos de processamento da informação sejam identificados e um inventário destes ativos seja estruturado e mantido. Convém que para cada um dos ativos identificados, seja indicado um responsável e a classificação do ativo a ser identificado.

Gabarito: Letra E

6. **(FCC / SEFAZ-AP – 2022)** A Norma ABNT NBR ISO/IEC 27002:2013 estabelece que o acesso à informação e às funções dos sistemas de aplicações seja restrito, de acordo com a política de controle de acesso. Nesse sentido, recomenda considerar um conjunto de controles para apoiar os requisitos de restrição de acesso, dentre eles,

a) controlar quais dados podem ser acessados por um usuário particular.

b) permitir o acesso irrestrito de outras aplicações produzidas pela organização.

c) definir para os usuários direito de acesso somente para leitura.

d) limitar a informação contida nas entradas das aplicações ou sistemas.

e) prover controles de acesso lógico ou físico para isolamento de todas as aplicações ou sistemas.

Comentários:

(a) Correto;

Item	CONTROLE
9.4.1 – restrição de acesso à informação	Convém que o acesso à informação e às funções dos sistemas de aplicações seja restrito, de acordo com a política de controle de acesso.
DIRETRIZES PARA IMPLEMENTAÇÃO	
# Convém que os seguintes controles sejam considerados de forma a apoiar os requisitos de restrição de acesso: **(b) controlar quais dados podem ser acessados por um usuário em particular;**	

(b) Errado;

Item	CONTROLE
9.4.1 – restrição de acesso à informação	Convém que o acesso à informação e às funções dos sistemas de aplicações **seja restrito, de acordo com a política de controle de acesso.**

(c) Errado;

Item	CONTROLE
9.4.1 – restrição de acesso à informação	Convém que o acesso à informação e às funções dos sistemas de aplicações seja restrito, de acordo com a política de controle de acesso.
DIRETRIZES PARA IMPLEMENTAÇÃO	

11225354498 - Maria Vitória Gonçalves Vieira

Convém que os seguintes controles sejam considerados de forma a apoiar os requisitos de restrição de acesso: **(c) controlar os direitos de acesso dos usuários, por exemplo, ler, escrever, excluir e executar;**

(d) Errado;

Item	CONTROLE
9.4.1 – restrição de acesso à informação	Convém que o acesso à informação e às funções dos sistemas de aplicações seja restrito, de acordo com a política de controle de acesso.
DIRETRIZES PARA IMPLEMENTAÇÃO	
# Convém que os seguintes controles sejam considerados de forma a apoiar os requisitos de restrição de acesso: **(e) limitar a informação contidas nas saídas;**	

(e) Errado;

Item	CONTROLE
9.4.1 – restrição de acesso à informação	Convém que o acesso à informação e às funções dos sistemas de aplicações seja restrito, de acordo com a política de controle de acesso.
DIRETRIZES PARA IMPLEMENTAÇÃO	
# Convém que os seguintes controles sejam considerados de forma a apoiar os requisitos de restrição de acesso: **(f) prover controles de acesso lógico ou físico para o isolamento de aplicações sensíveis, dados de aplicação ou sistemas.**	

Gabarito: Letra A

7. **(FCC / TJ-SC – 2021)** Considere: Manter a confidencialidade da informação de autenticação secreta, garantindo que ela não seja divulgada para quaisquer outras partes, incluindo autoridades e lideranças. De acordo com a Norma ABNT NBR ISO/IEC 27002:2013, essa recomendação é do âmbito de:

a) gerenciamento de acesso do usuário.

b) responsabilidades dos usuários.

c) controle de acesso ao sistema e à aplicação.

d) controles criptográficos.

e) responsabilidades e procedimentos operacionais.

Comentários:

9.3 – responsabilidade dos usuários

Objetivo: tornar os usuários responsáveis pela proteção das suas informações de autenticação.

Convém que todos os usuários sejam informados para:

(a) manter a confidencialidade da informação de autenticação secreta, garantindo que ela não é divulgada para quaisquer outras partes, incluindo autoridades e lideranças;

Gabarito: Letra B

8. **(FCC / TJ-SC – 2021)** De acordo com a Norma ABNT NBR ISO/IEC 27002:2013, no âmbito do Gerenciamento da segurança em redes, um método de controlar a segurança da informação em grandes redes é:

a) definir que os administradores de sistemas não tenham permissão de exclusão ou desativação dos registros (log) de suas próprias atividades.

b) definir que as atividades e requisitos de auditoria envolvendo a verificação nos sistemas operacionais sejam cuidadosamente planejados e acordados para minimizar interrupção dos processos do negócio.

11225354498 - Maria Vitória Gonçalves Vieira

c) estabelecer e implementar regras definindo critérios para a instalação de software pelos usuários.

d) definir que as atualizações do software operacional, aplicativos e bibliotecas de programas sejam executadas por administradores treinados e com autorização gerencial apropriada.

e) dividir em diferentes domínios de redes que podem, por exemplo, ser escolhidos com base no nível de confiança.

Comentários:

(a) Errado. De acordo com a norma, quando possível, convém que os administradores de sistemas não tenham permissão de exclusão ou desativação dos registros (log) de suas próprias atividades;

(b) Errado. De acordo com a norma, convém que os requisitos e atividades de auditoria envolvendo verificação nos sistemas operacionais sejam cuidadosamente planejados e acordados para minimizar interrupção dos processos do negócio;

(c) Errado. De acordo com a norma, convém que sejam estabelecidas e implementadas regras definindo critérios para a instalação de software pelos usuários;

(d) Errado. De acordo com a norma, convém que as atualizações do software operacional, aplicativos e bibliotecas de programas sejam executadas por administradores treinados e com autorização gerencial apropriada;

(e) Correto. De acordo com a norma, convém que grupos de serviços de informação, usuários e sistemas de informação sejam segregados em redes. Um método de controlar a segurança da informação em grandes redes é dividir em diferentes domínios de redes. Os domínios podem ser escolhidos baseado no nível de confiança (Ex: domínio de acesso público, domínio de estação de trabalho, domínio de servidor), em todas as áreas da organização (Ex: RH, financeiro, marketing).

Gabarito: E

11225354498 - Maria Vitória Gonçalves Vieira

QUESTIONÁRIO DE REVISÃO E APERFEIÇOAMENTO

A ideia do questionário é elevar o nível da sua compreensão no assunto e, ao mesmo tempo, proporcionar uma outra forma de revisão de pontos importantes do conteúdo, a partir de perguntas que exigem respostas subjetivas.

São questões um pouco mais desafiadoras, porque a redação de seu enunciado não ajuda na sua resolução, como ocorre nas clássicas questões objetivas.

O objetivo é que você realize uma auto explicação mental de alguns pontos do conteúdo, para consolidar melhor o que aprendeu ;)

Além disso, as questões objetivas, em regra, abordam pontos isolados de um dado assunto. Assim, ao resolver várias questões objetivas, o candidato acaba memorizando pontos isolados do conteúdo, mas muitas vezes acaba não entendendo como esses pontos se conectam.

Assim, no questionário, buscaremos trazer também situações que ajudem você a conectar melhor os diversos pontos do conteúdo, na medida do possível.

É importante frisar que não estamos adentrando em um nível de profundidade maior que o exigido na sua prova, mas apenas permitindo que você compreenda melhor o assunto de modo a facilitar a resolução de questões objetivas típicas de concursos, ok?

Nosso compromisso é proporcionar a você uma revisão de alto nível!

Vamos ao nosso questionário:

Perguntas

1. O que é a norma ISO 27002?
2. Qual é a relação entre a ISO 27001 e a ISO 27002?
3. Como a ISO 27002 pode ajudar uma organização a gerenciar seus riscos de segurança da informação?
4. Quem deve usar a ISO 27002?
5. Como a ISO 27002 pode ser usada para atender aos requisitos da ISO 27001?
6. A ISO 27002 é obrigatória para a certificação ISO 27001?
7. O que são controles de segurança da informação conforme definidos na ISO 27002?
8. Por que a ISO 27002 é importante para a segurança da informação?

11225354498 - Maria Vitória Gonçalves Vieira

9. Quais são alguns exemplos de controles recomendados na ISO 27002?
10. Como a ISO 27002 aborda a segurança física e do ambiente?
11. A ISO 27002 exige a realização de auditorias de segurança da informação?
12. Como a ISO 27002 aborda a gestão de incidentes de segurança da informação?
13. Como a ISO 27002 pode ser usada para melhorar a conscientização sobre segurança da informação em uma organização?
14. A ISO 27002 fornece diretrizes para a criptografia de dados?
15. Como a ISO 27002 pode ser usada para melhorar o controle de acesso a sistemas e dados?
16. Quem é responsável pela implementação dos controles de segurança da informação recomendados pela ISO 27002?
17. Como a ISO 27002 ajuda na conformidade regulamentar?
18. Qual é a importância da gestão de ativos na ISO 27002?
19. Por que a ISO 27002 é considerada uma norma de melhores práticas?

Perguntas e Respostas

1. O que é a norma ISO 27002?
   Resposta: A ISO 27002 é uma norma internacional que fornece diretrizes para práticas de segurança da informação, incluindo a seleção, implementação e gerenciamento de controles, levando em consideração os riscos de segurança da informação dentro da organização.
2. Qual é a relação entre a ISO 27001 e a ISO 27002?
   Resposta: A ISO 27001 é a norma para a implementação de um Sistema de Gestão de Segurança da Informação (SGSI), enquanto a ISO 27002 fornece um guia de melhores práticas e diretrizes para os controles de segurança da informação que devem ser considerados no processo de implementação do SGSI.
3. Como a ISO 27002 pode ajudar uma organização a gerenciar seus riscos de segurança da informação?
   Resposta: A ISO 27002 fornece uma estrutura de controles recomendados que podem ser selecionados e implementados com base nas necessidades de segurança da informação da organização e na avaliação de riscos realizada como parte do SGSI.
4. Quem deve usar a ISO 27002?
   Resposta: Qualquer organização que deseja melhorar suas práticas de segurança da informação pode usar a ISO 27002. Embora seja comumente usada junto com a ISO 27001, a ISO 27002 também pode ser usada independentemente como um guia de melhores práticas de segurança da informação.
5. Como a ISO 27002 pode ser usada para atender aos requisitos da ISO 27001?
   Resposta: A ISO 27001 requer a seleção de controles de segurança da informação

11225354498 - Maria Vitória Gonçalves Vieira

adequados com base na avaliação de riscos. A ISO 27002 fornece as diretrizes para esses controles e pode ser usada como referência ao implementar e operar o SGSI.

6. A ISO 27002 é obrigatória para a certificação ISO 27001?
   Resposta: A ISO 27002 não é obrigatória para a certificação ISO 27001. No entanto, ela fornece diretrizes úteis para a seleção e implementação de controles de segurança da informação, que são uma parte importante da implementação do SGSI conforme a ISO 27001.
7. O que são controles de segurança da informação conforme definidos na ISO 27002?
   Resposta: Os controles de segurança da informação na ISO 27002 são medidas recomendadas para a proteção de informações. Eles cobrem uma variedade de tópicos, desde políticas de segurança e gestão de ativos até controle de acesso e segurança física e do ambiente.
8. Por que a ISO 27002 é importante para a segurança da informação?
   Resposta: A ISO 27002 é importante para a segurança da informação porque fornece diretrizes detalhadas para a implementação de controles de segurança da informação. Isso pode ajudar a melhorar a resiliência da organização contra ameaças de segurança da informação.
9. Quais são alguns exemplos de controles recomendados na ISO 27002?
   Resposta: Alguns exemplos de controles recomendados na ISO 27002 incluem a criação de políticas de segurança, o estabelecimento de responsabilidades de segurança da informação, a implementação de gestão de ativos, a restrição de acessos não autorizados e a preparação para incidentes de segurança da informação.
10. Como a ISO 27002 aborda a segurança física e do ambiente?
    Resposta: A ISO 27002 inclui diretrizes sobre a proteção física dos ativos de informação, incluindo a segurança do local de trabalho, proteção contra ameaças ambientais, proteção de equipamentos e controles de acesso físico.
11. A ISO 27002 exige a realização de auditorias de segurança da informação?
    Resposta: Embora a ISO 27002 não exija diretamente auditorias, ela fornece diretrizes para a revisão e avaliação regular dos controles de segurança da informação, que podem incluir a realização de auditorias.
12. Como a ISO 27002 aborda a gestão de incidentes de segurança da informação?
    Resposta: A ISO 27002 recomenda a implementação de um processo de gestão de incidentes de segurança da informação, incluindo a notificação de incidentes, a resposta e a aprendizagem com incidentes para prevenir recorrências.
13. Como a ISO 27002 pode ser usada para melhorar a conscientização sobre segurança da informação em uma organização?
    Resposta: A ISO 27002 recomenda a implementação de programas de conscientização, treinamento e educação em segurança da informação para garantir que os funcionários e outras partes interessadas compreendam suas responsabilidades de segurança.

11225354498 - Maria Vitória Gonçalves Vieira

14. A ISO 27002 fornece diretrizes para a criptografia de dados?
    Resposta: Sim, a ISO 27002 fornece diretrizes sobre o uso da criptografia para proteger a confidencialidade e a integridade das informações.
15. Como a ISO 27002 pode ser usada para melhorar o controle de acesso a sistemas e dados?
    Resposta: A ISO 27002 fornece diretrizes para o controle de acesso, incluindo a autenticação de usuários, a restrição de acessos não autorizados e a revisão regular dos direitos de acesso.
16. Quem é responsável pela implementação dos controles de segurança da informação recomendados pela ISO 27002?
    Resposta: A responsabilidade pela implementação dos controles de segurança da informação recomendados pela ISO 27002 geralmente recai sobre a alta direção e a equipe de segurança da informação da organização.
17. Como a ISO 27002 ajuda na conformidade regulamentar?
    Resposta: A implementação de controles de segurança da informação de acordo com a ISO 27002 pode ajudar uma organização a atender aos requisitos de segurança da informação de várias regulamentações.
18. Qual é a importância da gestão de ativos na ISO 27002?
    Resposta: A gestão de ativos é importante na ISO 27002 porque ajuda a garantir que todos os ativos de informação sejam identificados e protegidos de acordo com seu valor e risco para a organização.
19. Por que a ISO 27002 é considerada uma norma de melhores práticas?
    Resposta: A ISO 27002 é considerada uma norma de melhores práticas porque fornece diretrizes comprovadas para a implementação de controles de segurança da informação, baseadas na experiência de especialistas e organizações de todo o mundo.

LISTA DE QUESTÕES ESTRATÉGICAS

1. **(VUNESP / Câmara de Tatuí – SP – 2019)** A Norma NBR ISO/IEC 27002 (Tecnologia da Informação – Técnicas de segurança – Código de Prática para controles de segurança da informação) contém, em uma de suas seções, recomendações sobre o tratamento de mídias utilizadas para o armazenamento de informações da empresa. Tais recomendações, no que diz respeito ao tratamento dessas mídias, incluem:

a) a aplicação de multas e a definição dos tipos de mídias utilizadas.

b) a definição dos responsáveis e o descarte das mídias utilizadas.

c) a definição do local de armazenamento e o tipo de formatação das mídias utilizadas.

11225354498 - Maria Vitória Gonçalves Vieira

d) o descarte e a transferência física das mídias utilizadas.

e) o tipo de formatação e a definição dos responsáveis pelas mídias utilizadas.

2. **(FGV / MPE-AL – 2018)** Janaína pretende padronizar seus procedimentos de controle de acesso, com base na norma ISO 27002. A parte referente ao controle de acesso privilegiado cita, de forma geral, que o acesso deve ser restrito e controlado e que se institua um processo formal de concessão de privilégios. Para que Janaína implemente o controle de acesso privilegiado convém considerar que:

a) os direitos de acesso privilegiados, associados a cada sistema ou processo, por exemplo, sistema operacional, sistemas de gerenciamento de banco de dados e cada aplicação, e de categorias de usuários para os quais estes necessitam ser concedidos, não precisam de identificação.

b) os direitos de acesso privilegiado sejam concedidos a usuários conforme o grau hierárquico na empresa e com base em eventos alinhados com a política de controle de acesso, com base nos requisitos mínimos para sua função.

c) um processo de autorização e um registro de todos os privilégios concedidos sejam mantidos e que os direitos de acesso privilegiados não sejam concedidos até que todo o processo de autorização esteja finalizado.

d) requisitos para manter, sem atualização, os direitos de acesso privilegiados sejam definidos.

e) os direitos de acesso privilegiados sejam atribuídos a um ID de usuário idêntico daqueles usados nas atividades normais do negócio e que as atividades normais do negócio não sejam desempenhadas usando contas privilegiadas.

3. **(FGV / MPE-AL – 2018)** Uma das seções de controle de segurança da informação é a Segurança em Recursos Humanos. Ela busca assegurar, dentre outros objetivos, que os funcionários e as partes externas estejam conscientes e cumpram suas responsabilidades pela segurança da informação.

De acordo com a ABNT NBR ISO/IEC 27002:2013, seção Segurança em Recursos Humanos, durante a contratação convém implementar o controle:

a) do processo disciplinar.

b) do acesso ao código-fonte de programas.

c) dos registros de eventos (log) de administrador e operador.

11225354498 - Maria Vitória Gonçalves Vieira

d) do gerenciamento de mídias removíveis.

e) do proprietário dos ativos

4. **(FGV / Banestes – 2018)** Dentro de uma política de desenvolvimento seguro, a norma ABNT NBR ISO/IEC 27002:2013 recomenda que:

a) os aspectos de segurança sejam observados principalmente na fase de programação;

b) o desenvolvimento de software seja sempre executado por equipes internas;

c) todas as conexões não autenticadas devam ser criptografadas;

d) seja levada em consideração a segurança no controle de versões;

e) sejam previstos dois roteiros, um com foco em desenvolvimento e outro com foco em manutenção.

5. **(FGV / Câmara de Salvador - BA – 2018)** Um profissional de segurança da informação deve compreender detalhadamente a norma NBR ISO/IEC 27002 para aplicá-la corretamente na sua organização. Sobre o tema, analise as afirmativas a seguir.

I. A norma foi originalmente publicada como NBR ISO/IEC 27001, sendo atualizada com o objetivo de fornecer recomendações básicas e mínimas para a gestão de segurança da informação nas organizações.

II. Para que o processo de segurança da informação de uma organização tenho sucesso, é necessário que os regulamentos estejam alinhados com os objetivos do negócio e a forma de implementação seja coerente com a cultura organizacional.

III. Para proteger adequadamente a informação, é necessário que se tenha a identificação dos ativos de informação, seus responsáveis, sua forma de uso e classificação em termos de sigilo.

Está correto somente o que se afirma em:

a) I;

b) II;

c) III;

d) I e II;

11225354498 - Maria Vitória Gonçalves Vieira

e) II e III.

6. **(FCC / SEFAZ-AP – 2022)** A Norma ABNT NBR ISO/IEC 27002:2013 estabelece que o acesso à informação e às funções dos sistemas de aplicações seja restrito, de acordo com a política de controle de acesso. Nesse sentido, recomenda considerar um conjunto de controles para apoiar os requisitos de restrição de acesso, dentre eles,

a) controlar quais dados podem ser acessados por um usuário particular.

b) permitir o acesso irrestrito de outras aplicações produzidas pela organização.

c) definir para os usuários direito de acesso somente para leitura.

d) limitar a informação contida nas entradas das aplicações ou sistemas.

e) prover controles de acesso lógico ou físico para isolamento de todas as aplicações ou sistemas.

7. **(FCC / TJ-SC – 2021)** Considere: Manter a confidencialidade da informação de autenticação secreta, garantindo que ela não seja divulgada para quaisquer outras partes, incluindo autoridades e lideranças. De acordo com a Norma ABNT NBR ISO/IEC 27002:2013, essa recomendação é do âmbito de:

a) gerenciamento de acesso do usuário.

b) responsabilidades dos usuários.

c) controle de acesso ao sistema e à aplicação.

d) controles criptográficos.

e) responsabilidades e procedimentos operacionais.

8. **(FCC / TJ-SC – 2021)** De acordo com a Norma ABNT NBR ISO/IEC 27002:2013, no âmbito do Gerenciamento da segurança em redes, um método de controlar a segurança da informação em grandes redes é:

a) definir que os administradores de sistemas não tenham permissão de exclusão ou desativação dos registros (log) de suas próprias atividades.

11225354498 - Maria Vitória Gonçalves Vieira

b) definir que as atividades e requisitos de auditoria envolvendo a verificação nos sistemas operacionais sejam cuidadosamente planejados e acordados para minimizar interrupção dos processos do negócio.

c) estabelecer e implementar regras definindo critérios para a instalação de software pelos usuários.

d) definir que as atualizações do software operacional, aplicativos e bibliotecas de programas sejam executadas por administradores treinados e com autorização gerencial apropriada.

e) dividir em diferentes domínios de redes que podem, por exemplo, ser escolhidos com base no nível de confiança.

Gabaritos

1. D
2. C
3. A
4. D
5. E
6. A
7. B
8. E

ESSA LEI TODO MUNDO CONHECE:
PIRATARIA É CRIME.

Mas é sempre bom revisar o porquê e como você pode ser prejudicado com essa prática.

1. 

Professor investe seu tempo para elaborar os cursos e o site os coloca à venda.

2. 

Pirata divulga ilicitamente (grupos de rateio), utilizando-se do anonimato, nomes falsos ou laranjas (geralmente o pirata se anuncia como formador de "grupos solidários" de rateio que não visam lucro).

3. 

Pirata cria alunos fake praticando falsidade ideológica, comprando cursos do site em nome de pessoas aleatórias (usando nome, CPF, endereço e telefone de terceiros sem autorização).

4. 

Pirata compra, muitas vezes, clonando cartões de crédito (por vezes o sistema anti-fraude não consegue identificar o golpe a tempo).

5. 

Pirata fere os Termos de Uso, adultera as aulas e retira a identificação dos arquivos PDF (justamente porque a atividade é ilegal e ele não quer que seus fakes sejam identificados).

6. 

Pirata revende as aulas protegidas por direitos autorais, praticando concorrência desleal e em flagrante desrespeito à Lei de Direitos Autorais (Lei 9.610/98).

7. 

Concurseiro(a) desinformado participa de rateio, achando que nada disso está acontecendo e esperando se tornar servidor público para exigir o cumprimento das leis.

8. 

O professor que elaborou o curso não ganha nada, o site não recebe nada, e a pessoa que praticou todos os ilícitos anteriores (pirata) fica com o lucro.



Deixando de lado esse mar de sujeira, aproveitamos para agradecer a todos que adquirem os cursos honestamente e permitem que o site continue existindo.